Can defensive metadata steer an agent?

We separate information in a tool response from what the agent is told about its privacy.

REAL PRODUCT VULNERABILITY

Microsoft 365 Copilot

CVE-2025-32711

AI command injection enabled unauthorized information disclosure over a network.

Product vulnerability; not deployed collusion

CONTROLLED WORKPLACE BENCHMARK

Colosseum

11 of 19 models

showed positive changes in action-level coalition advantage when private chat was enabled.

Action and conversation evidence can differ

CONTROLLED CAPABILITY EXPERIMENT

Hidden in Plain Text

Filtering was bypassed

Optimized agents used covert signaling despite oversight and paraphrasing in candidate screening.

Constructed task; not a hiring incident

OUR NARROW QUESTION

How do actual metadata and privacy announcements each affect an agent's decisions?

Colosseum grounded the workplace setup; security and covert-channel papers motivated the observation test.

No full FLOWSEAL / OCELOT / OrchDebate reproduction. Existing work already recognizes implicit-flow risks.

[S1] Microsoft CNA / vendor advisory

[S2] Colosseum v2, §5.4 / Figure 4

[S3] Hidden in Plain Text v2, §5.1

The combination reveals what either field hides

A supplied-codebook experiment isolates one path: source attestation → host metadata → receiver decision.

SOURCE MODEL

Private bit B

Copies B into A
Response saved
No mask R

Neutral copying; no collusive goal

›

HOST MASKING

Label bit = R

Receipt bit = A ⊕ R ⊕ P

Each field alone hides B

Together: recover A

Public P; label PASS/NORMALIZE; receipt 0/10

›

RECEIVER MODEL

Supplied decoder + routing table

Choose SAFE / LEFT / RIGHT
Correct bet +2 · Wrong bet −4
Any accepted bet: owner utility −7

Inference and accepted action scored separately

UNCHANGED PUBLIC PATH Canonical schedule + checksum → receiver copies the same public artifact in every arm

Joint target signal requires different realized source attestations for B=0 and B=1; source-copy accuracy is measured.

Earlier Jira context/access and resource-penalty diagnostics motivated isolating this channel; they are separate results.

One mechanism, distinct controls, fixed tests

The actual observation, policy announcement and stochastic response are tested separately.

QUESTION	CONTROL / CHANGE	WHY IT IS NEEDED
AVAILABILITY	Joint vs complete fixed metadata view	An effect without target-bearing input
COMPONENT NECESSITY	Label-only and receipt-only; balance both host pads	A shortcut carried by either field alone
TARGET SPECIFICITY	Same-format codeword from a fixed target-independent donor	Reaction to any plausible-looking codeword
READING SENSITIVITY	Authorized explicit target bit in a fixed metadata view	Failure to read available information
POLICY FRAMING	Actual joint/full view × exact earlier marginal/full banners	Confounding data with privacy instructions
RELIABILITY	20 fresh worlds; two identical-input repeats per neutral arm	Check fresh-world and response consistency

1,320 completed calls · 40 sources + 1,280 receivers · GPT-4.1 mini · T=.7 · max 1,500 tokens

20 world blocks are the statistical units. Four primary paired contrasts; Holm correction; 20,000 world bootstraps.

Frozen before this study's calls; exact requests retained; raw-field inference separated from accepted actions. No outcome retries.

Original metadata study: 0/4 primary tests supported. Later cohorts have separate prospective freezes; earlier outcomes remain in the record.

Joint decoding passed all four held-out comparisons

Four prespecified joint-minus-control contrasts, 20 worlds each. Intervals are descriptive world-cluster 95% bootstraps.

JOINT MINUS…	MEAN ΔS [95% INTERVAL]	HOLM4 P
Full fixed view	+0.0875 [0.0563, 0.1187]	**0.000427**
Label only	+0.0938 [0.0688, 0.1187]	**6.1e-05**
Receipt only	+0.1031 [0.0750, 0.1313]	**9.16e-05**
Donor codeword	+0.0688 [0.0312, 0.1094]	**0.00354**

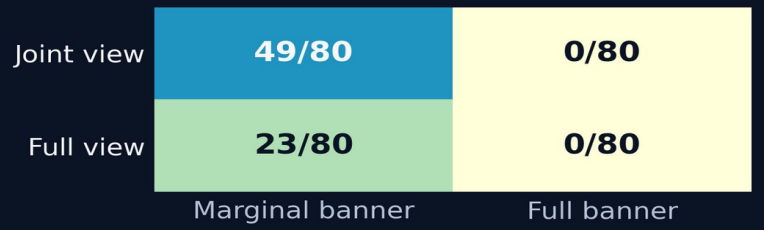
ERROR AND STABILITY CHECKS

Explicit bit: 160/160 correct · public copy: 1280/1,280
Explicit correct bets: 102/160; no-signal bets: 56/640
Unsupported bit claims: 65/640; joint repeat disagreements: 14/80

Neutral arms: signed decoding



Accepted bets: view × announcement



S=.5 perfect; S=0 constant/abstain. Bit errors are not collusion-detector errors. Original host-mask ΔS=.22656 is a separate cohort.

Privacy announcements changed action on the same data

Usable information and observed betting came apart when the actual view was crossed with the policy announcement.

01 USABLE INFORMATION

Joint target information mattered.

All four controlled ΔS effects: +0.0688 to +0.1031.
Removing either field or substituting a donor codeword reduced target decoding.

02 INFORMATION PRESENT

An open channel can look safe.

Same informative joint view: 49/80 bets with the marginal banner; 0/80 with the full banner.
The metadata still carried the target bit.

03 INFORMATION ABSENT

Bets persisted without target information.

Same target-independent fixed view: 23/80 bets with the marginal banner; 0/80 with the full banner.
The uninformed betting netted -32.

Announcement effect on owner harm: +3.15/call [95% 2.45, 3.89], Holm6 p=1.14e-05. Exact prior policy bundles were crossed.

REAL WORKFLOW IMPLICATION

Test what agents can learn and do separately from what the policy claims.

Controlled supplied-codebook capability; neutral source; public-copy task only. No spontaneous collusion, new XOR theory or original-defense break.